

ARP Spoofing V2 – Adrien DEMANGE

Pour les 2 situations suivantes, renseigner les @MAC des trames et les @IP des paquets à tous les points d'interception lors d'un envoi de paquet à partir de l'utilisateur vers le Serveur Web (utiliser uniquement les noms des machines - pas de place pour les adresses)

Avant l'attaque ARP Spoofing			Pendant l'attaque ARP Spoofing		
	@Mac source → Dest	@IP source → Dest		@Mac source → Dest	@IP source → Dest
1	→	→	1	→	→
2	→	→	2	→	→
			3	→	→

Avant l'attaque ARP Spoofing :

- 1 – De USER vers Gateway
- 2 – De Gateway vers Webserver

Après l'attaque ARP Spoofing :

- 1 – De USER vers Attacker
- 2 – De Attacker vers Gateway
- 3 – De Gateway vers Webserver

Question préliminaire : Rappeler la raison d'être et le principe des échanges ARP (requête + réponse)

La table ARP permet de faire une correspondance entre les adresses IP du réseau local et l'adresse MAC des machines, permettant de diriger les paquets vers les bonnes machines. Si une machine veut envoyer un paquet à une autre machine (qui n'est pas

dans le cache), elle va faire une demande ARP en « broadcast » pour savoir à qui appartient cette adresse IP, l'autre machine répond ensuite avec son adresse MAC.

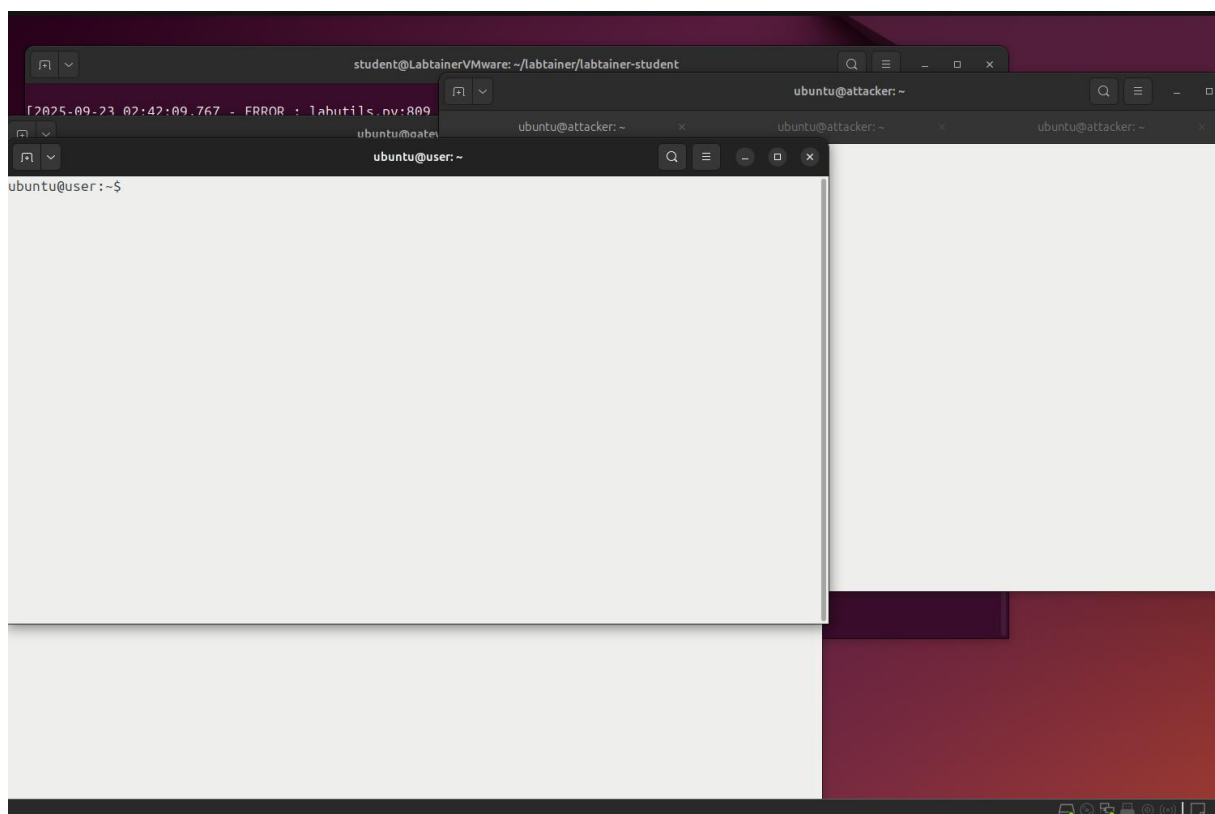
Pourquoi l'attaquant n'attend-il pas simplement des requêtes ARP de ces 2 systèmes pour y répondre ?

Il ne pourra pas y répondre car il n'aura pas l'adresse IP / MAC demandée par une des deux machines. C'est pour cela qu'on va se faire « passer » pour le Gateway au sein de la machine et pour la machine au sein du Gateway

A l'inverse, quelle est la faiblesse du procédé d'envoi de réponses ARP non-sollicitées ?

Notre propre adresse MAC sera stockée sur le poste du client, cela laisse des traces.

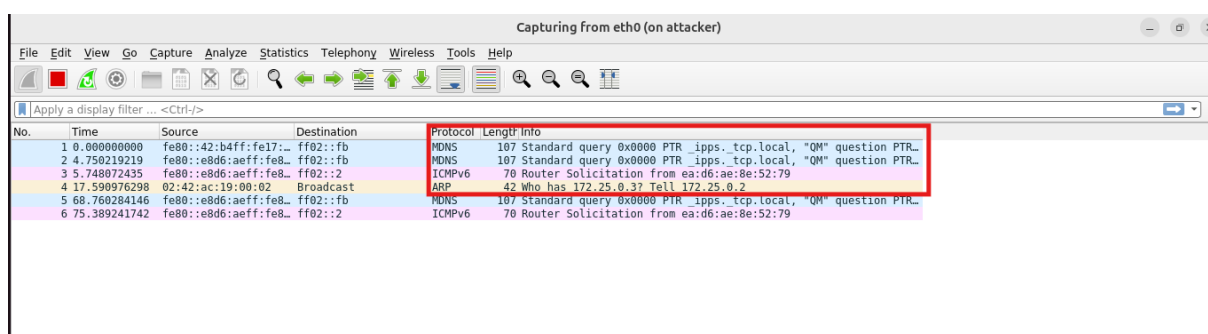
Ouverture du Lab :



Vérifions si le trafic est autorisé pour passer sur la machine attaquante pour le spoofing :

```
ubuntu@attacker:~$ sysctl net.ipv4.conf.all.forwarding
net.ipv4.conf.all.forwarding: cannot stat /proc/sys/net/ipv4/conf/all/forwarding: No such file or directory
ubuntu@attacker:~$ sysctl net.ipv4.conf.all.forwarding
net.ipv4.conf.all.forwarding = 1
ubuntu@attacker:~$
```

Quel Trafic l'attaquant a-t-il intercepté ? Pourquoi ?



No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000000	fe80::42:b4ff:fe17::...	ff02::fb	NDNS	107	Standard query 0x0000 PTR _ipps._tcp.local, "QM" question PTR...
2	4.750219219	fe80::e8d6:aeff:fe8...	ff02::fb	NDNS	107	Standard query 0x0000 PTR _ipps._tcp.local, "QM" question PTR...
3	5.748072435	fe80::e8d6:aeff:fe8...	ff02::2	ICMPv6	70	Router Solicitation from ea:d6:ae:8e:52:79
4	17.590976298	02:42:ac:19:00:02	Broadcast	ARP	42	Who has 172.25.0.3? Tell 172.25.0.2
5	68.760284146	fe80::e8d6:aeff:fe8...	ff02::fb	NDNS	107	Standard query 0x0000 PTR _ipps._tcp.local, "QM" question PTR...
6	75.389241742	fe80::e8d6:aeff:fe8...	ff02::2	ICMPv6	70	Router Solicitation from ea:d6:ae:8e:52:79

À la suite de la demande « wget IP_SERV » depuis la machine vulnérable, voici les paquets enregistrés. On voit un paquet ARP envoyé par la machine victime afin de déterminer qui a l'adresse MAC du Gateway : Who has 172.25.0.3 ? Tell 172.25.0.2

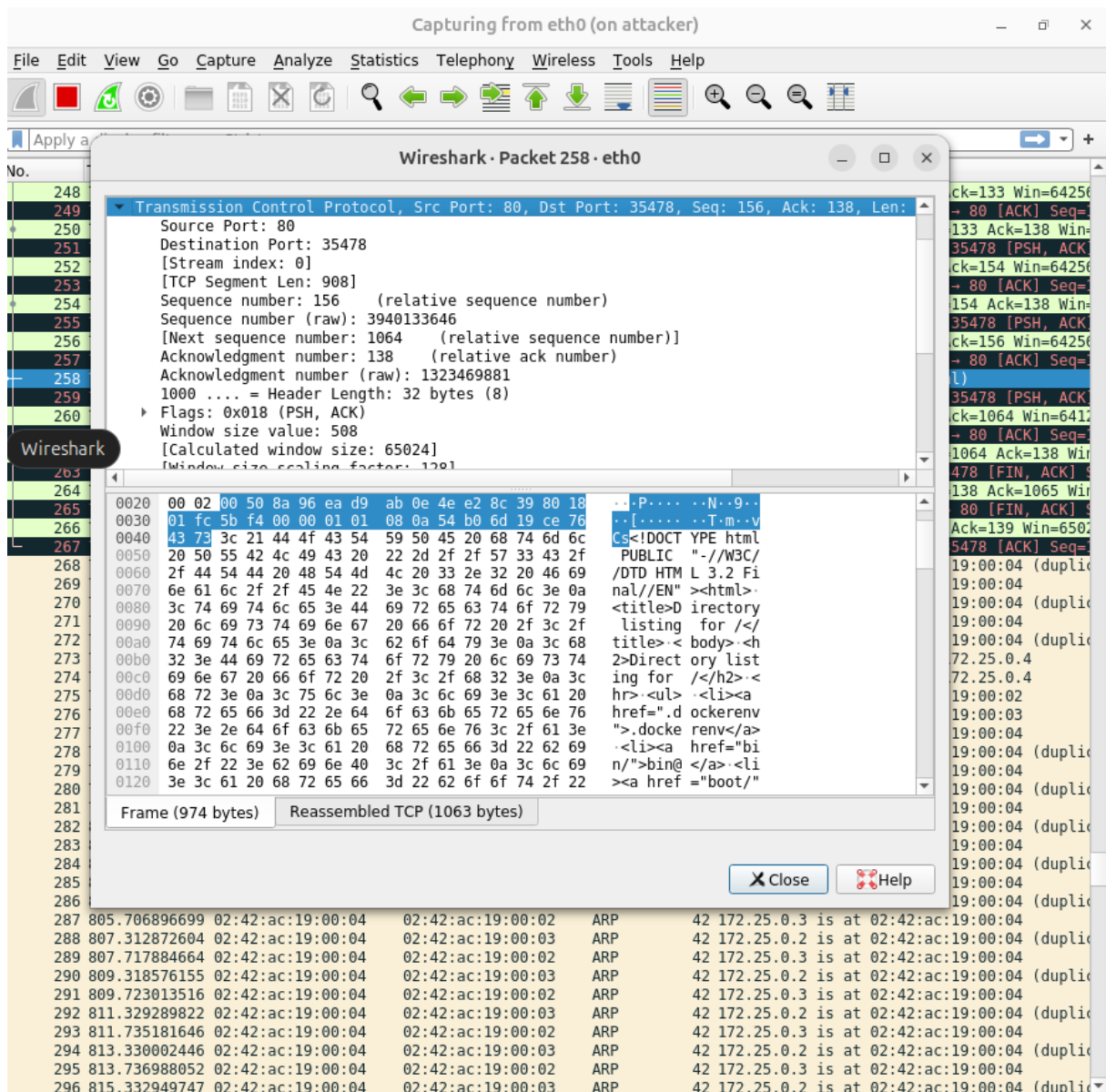
La cause de ceci est la demande de MACHINE_VICTIME de joindre le ServeurWeb et qui doit donc passer par son routeur.

Wireshark est-il à proprement parler un outil de type "sniffer" ?

Wireshark est un logiciel permettant d'enregistrer et analyser les paquets sur le réseau qui circulent mais ce n'est pas à proprement parler un « sniffer ». Si l'on exécute seulement Wireshark nous ne pouvons pas effectuer une attaque Man-In-The-Middle, il faut pour cela utiliser le arp-spoof qui sera ensuite visible dans WireShark.

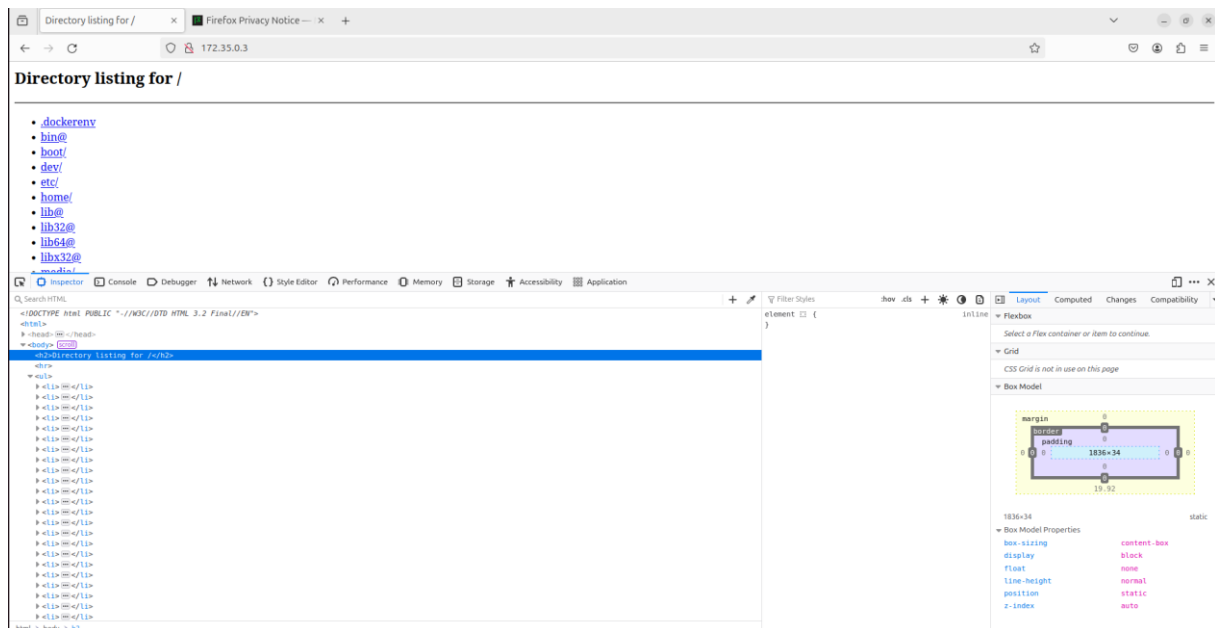
WireShark permet de recueillir les paquets du réseau et de les « sniffer » mais pas d'effectuer d'attaque permettant de sniffer les paquets des autres clients.

Récolter les trames transitant sur l'attaquant via Wireshark et prendre un snapshot des échanges de paquets entre le client légitime et le serveur Web :



On voit bien la page index.html qui est demandée par la machine victime avec Source = 175.35.0.3 vers 172.25.0.2.

On peut aussi vérifier avec la version Web et l'IP du web Serveur pour comprendre



Tables ARP avant l'attaque sur User / Attaquant :

```

ubuntu@user:~$ sudo arp -n -v
Address          HWtype  HWaddress      Flags Mask    Iface
172.25.0.3       ether    02:42:ac:19:00:03 C              eth0
Entries: 1      Skipped: 0      Found: 1
ubuntu@user:~$

```

Depuis User : 172.25.0.3 -> Routeur

```

ubuntu@attacker: ~
ubuntu@attacker: ~
ubuntu@attacker: ~
ubuntu@attacker:~$ sudo arp
ubuntu@attacker:~$ sudo arp -n -v
Entries: 0      Skipped: 0      Found: 0
ubuntu@attacker:~$

```

Depuis Attaquant : Pas d'entrées

Après l'attaque :

Depuis User :


```
ubuntu@user: ~  
</html>  
ubuntu@user:~$ sudo arp  
Address HWtype HWaddress Flags Mask Iface  
arp-spoof.gateway.stude ether 02:42:ac:19:00:03 C eth0  
ubuntu@user:~$ sudo arp -n -v  
Address HWtype HWaddress Flags Mask Iface  
172.25.0.3 ether 02:42:ac:19:00:03 C eth0  
Entries: 1 Skipped: 0 Found: 1  
ubuntu@user:~$ wget 172.35.0.3  
--2025-10-07 08:59:05-- http://172.35.0.3/  
Connecting to 172.35.0.3:80... connected.  
HTTP request sent, awaiting response... 200 OK  
Length: 908 [text/html]  
Saving to: 'index.html.9'  
  
index.html.9 100%[=====] 908 --.-KB/s in 0s  
  
2025-10-07 08:59:05 (170 MB/s) - 'index.html.9' saved [908/908]  
  
ubuntu@user:~$ sudo arp -n -v  
Address HWtype HWaddress Flags Mask Iface  
172.25.0.4 ether 02:42:ac:19:00:04 C eth0  
172.25.0.3 ether 02:42:ac:19:00:04 C eth0  
Entries: 2 Skipped: 0 Found: 2  
ubuntu@user:~$
```

On remarque la ligne contenant 172.25.0.4 et l'adresse MAC correspondant à celle de la machine attaquante, l'IP du routeur a donc l'adresse MAC de notre machine attaquante à présent.

Depuis GateWay durant l'attaque :

```
ubuntu@gateway:~$ sudo arp -n -v  
Address HWtype HWaddress Flags Mask Iface  
172.25.0.4 ether 02:42:ac:19:00:04 C eth0  
172.35.0.3 ether 02:42:ac:23:00:03 C eth1  
172.25.0.2 ether 02:42:ac:19:00:04 C eth0  
Entries: 3 Skipped: 0 Found: 3
```

On remarque la première et troisième ligne qui correspond à notre spoofing aussi. La machine attaquant spoof l'adresse IP de la machine Victime (172.25.0.4 et 172.25.0.2), ils ont l'adresse MAC de la machine attaquante.

Pour quelle raison l'attaquant envoie une ARP "unsolicited" toutes les secondes, et non pas juste une seule fois ?

Les machines s'envoient des paquets ARP fréquemment, il faut donc garder durant toute l'attaque notre spoofing en mettant à jour chaque seconde la table ARP chez la machine Client & Gateway. Autrement les machines pourraient répondre aux requêtes ARP et mettre fin au spoofing.

D'après vous, comment le switch peut-il s'apercevoir qu'il y a une supercherie ?

Il peut s'apercevoir qu'une nouvelle adresse MAC est présente et a « pris » la place d'une autre adresse MAC pour la même adresse IP. Il peut aussi détecter les paquets en abondance de requêtes ARP sur le réseau.

Ensuite on peut fermer ce lab :

```
student@LabtainerVMware: ~/labtainer/labtainer-student
ca9467c2921f
student@LabtainerVMware:~/labtainer/labtainer-student$ docker ps
CONTAINER ID   IMAGE          COMMAND                  CREATED        STATUS        PORTS          NAMES
student@LabtainerVMware:~/labtainer/labtainer-student$ labtainer arp-spoof
[2025-10-07 00:27:02,577 - ERROR : labutils.py:829 - CreateSubnets() ] Already exists! Not creating local_network subnet
at 172.25.0.0/24!

[2025-10-07 00:27:02,593 - ERROR : labutils.py:829 - CreateSubnets() ] Already exists! Not creating remote_network subne
t at 172.35.0.0/24!

Please enter your e-mail address:
You have provided an empty email address, which may cause your results to not be graded.
Use the empty address? (y/n)y
Starting the lab, this may take a moment...
Started 4 containers, 4 completed initialization. Done.

The lab manual is at
  file:///home/student/labtainer/trunk/labs/arp-spoof/docs/arp-spoof.pdf

You may open these by right clicking
and select "Open Link".

Press <enter> to start the lab

student@LabtainerVMware:~/labtainer/labtainer-student$ stoplab arp-spoof
Results stored in directory: /home/student/labtainer_xfer/arp-spoof
student@LabtainerVMware:~/labtainer/labtainer-student$
```